

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Clínica Privada - Área de Seguridad de la Información

Dirigido a: Directorio de la Clínica

Fecha: Septiembre 2026

Elaborado por: Responsable de Seguridad de la Información

1. RESUMEN EJECUTIVO

En el marco de la reciente auditoría externa, que identificó debilidades en la gestión de riesgos de la organización, se llevó a cabo un relevamiento inicial de riesgos de seguridad de la información utilizando la herramienta SimpleRisk. Se identificaron 7 riesgos específicos vinculados a la operatoria diaria de la clínica (atención de 800 pacientes/día, manejo de historias clínicas digitales, datos de obras sociales y facturación), de los cuales 3 fueron clasificados en nivel Alto y requieren atención prioritaria. Para cada uno de estos 3 riesgos se definió un plan de acción con responsable, fecha de vencimiento y presupuesto estimado. El presente documento resume los hallazgos principales y las recomendaciones para el Directorio.

2. TOP 5 RIESGOS POR NIVEL

1) Filtración de datos de pacientes por mal manejo de backups y dispositivos USB — Nivel: Alto (8/10)

Categoría: Confidencialidad. No existen controles técnicos que impidan la conexión de dispositivos USB, ni políticas formales de manejo de backups, que actualmente se realizan sin cifrado.

2) Incumplimiento de la Ley 25.326 de Protección de Datos Personales — Nivel: Alto (8/10)

Categoría: Legal. La ausencia de políticas formales de tratamiento de datos personales y de salud incrementa la exposición a sanciones de la Agencia de Acceso a la Información Pública (AAIP).

3) Dependencia de un único administrador de sistemas — Nivel: Alto (8/10)

Categoría: Operativo. La clínica depende de un único responsable técnico, sin backup de personal ni documentación formal de procedimientos, lo que compromete la continuidad operativa ante una ausencia imprevista.

4) Acceso no autorizado a historias clínicas digitales — Nivel: Medio (6/10)

Categoría: Confidencialidad. Existen roles diferenciados de acceso, pero no hay trazabilidad (logs) de quién accede a qué historia clínica.

5) Modificación accidental o maliciosa de historias clínicas — Nivel: Medio (6/10)

Categoría: Integridad. No hay control de versiones ni registro de auditoría de cambios sobre datos clínicos, con riesgo directo sobre la seguridad del paciente (ej. errores de medicación).

3. ESTADO DE LOS PLANES DE ACCIÓN

Los 3 riesgos de nivel Alto cuentan con plan de acción en estado "Mitigation Planned" dentro de SimpleRisk:

- Filtración de datos (backups/USB): implementar bloqueo de puertos USB y cifrado de backups. Responsable: Seguridad de la Información. Presupuesto estimado: USD 100.001–200.000. Vencimiento: 60 días.
- Incumplimiento Ley 25.326: auditoría de cumplimiento normativo y designación de responsable de protección de datos. Responsable: Seguridad de la Información. Presupuesto estimado: USD 0–100.000. Vencimiento: 60 días.
- Dependencia de administrador único: documentación de procedimientos críticos (runbooks) y capacitación de personal de respaldo. Responsable: Seguridad de la Información. Presupuesto estimado: USD 0–100.000. Vencimiento: 90 días.

4. RECOMENDACIONES PRIORITARIAS

- Priorizar la implementación de controles de cifrado y restricción de dispositivos extraíbles (USB) dado el nivel de riesgo asociado a la fuga de información sensible de pacientes.
- Iniciar a la brevedad una revisión de cumplimiento normativo respecto a la Ley 25.326, dado el antecedente de la auditoría externa y la sensibilidad de los datos de salud tratados.
- Reducir la dependencia de un único responsable técnico mediante documentación de procesos y/o incorporación de soporte externo de respaldo.
- Incorporar registros de auditoría (logging) en el sistema de historias clínicas para mejorar la trazabilidad de accesos y modificaciones.
- Establecer un cronograma de revisión periódica del registro de riesgos, dado que la gestión de riesgos es un proceso continuo y no una actividad puntual.